🔖 التكليف الرابع عشر: أداة التفاعل مع DOM والوقاية من ثغرات DOM-XSS

1. الوصف العام للتكليف:

المطلوب هو بناء تطبيق ويب تفاعلي في جانب العميل (Client-Side) باستخدام لغة JavaScript يقوم بعرض مدخلات المستخدم ديناميكياً على الصفحة. تهدف الأداة إلى توضيح مخاطر استخدام الخصائص التي تترجم النصوص المباشرة كأكواد (مثل `innerHTML`) مقابل استخدام الطرق الآمنة لمعالجة العناصر (مثل `textContent`) لمنع ثغرات DOM-Based XSS.

2. خطوات انجاز التكليف:

- إنشاء واجهة HTML بسيطة تحتوي على حقل إدخال نصي وزري عرض (غير آمن / آمن).
- استقبال المدخلات باستخدام JavaScript والتقاط قيمتها عبر `document.getElementById().value`.
- تطبيق العرض غير الآمن بدمج النص مباشرة في الخاصية `innerHTML` وإثبات إمكانية تنفيذ وسوم HTML وJavaScript.
- تطبيق العرض الآمن بإسناد النص للخاصية `textContent` لضمان التعامل مع المدخلات كنص مجرد.
- اختبار الواجهة بـ Payload مثل `<img src=x onerror=alert(1)>` وملاحظة الفرق في التنفيذ بين الطريقتين.

3. الأدوات والحيل المساعده:

- استخدام `textContent` أو `innerText` بدلاً من `innerHTML` عند إدراج بيانات غير موثوقة في DOM.
- استخدام `document.createElement()` و `appendChild()` لبناء العناصر الهيكلية بشكل آمن.

4. معايير قبول الحل:

- نجاح العرض غير الآمن في إظهار الثغرة، ونجاح العرض الآمن في تحييد الأكواد وعرضها كنص فقط.
- عمل الواجهة بشكل مستقر وبدون أخطاء برمجية في الـ Browser Console.